Применение методов формальной верификации для анализа правил фильтрации сетевого трафика

Дурнов Алексей Николаевич
докладчик

Каплин Артём Андреевич

Ларин Дмитрий Викторович

Ефанов Николай Николаевич

Московский физико-технический институт
(национальный исследовательский университет)

Москва, 2026 г.

Актуальность проблемы

Рост киберугроз

- Ежегодный рост числа кибератак на 20–30%
- Усложнение атак: APT, многовекторные атаки, атаки на уровне приложений

Средства защиты класса NGFW

- Next-Generation Firewall становится одним из ключевых элементов сетевой безопасности
- В России активно развивается рынок отечественных решений: Kaspersky, Positive Technologies, UserGate, Континент, Ideco и др.
- Оставшиеся зарубежные решения: Check Point, Fortinet, Palo Alto Networks и др.

Цена ошибки

- Ошибки конфигурации политики безопасности — одна из главных причин инцидентов ИБ
- Средний ущерб от утечки данных в России - 11.5 млн рублей

Цель:

Разработка системы автоматического анализа и верификации правил фильтрации сетевого трафика для выявления ошибок конфигурации

Задачи:

1. Провести исследование существующих методов анализа правил фильтрации
2. Разработать унифицированную вендоро-независимую модель представления правил различных форматов. Модель должна поддерживать отечественные решения
3. Выбрать и адаптировать методы формальной верификации для анализа правил
4. Реализовать алгоритмы обнаружения ошибок конфигурации в наборах правил
5. Разработать прототип системы анализа правил фильтрации
6. Провести тестирование на реальных конфигурациях

Правила фильтрации сетевого трафика

Политика сетевой безопасности в первую очередь определяется набором правил фильтрации сетевого трафика.

Основные классы правил фильтрации:

1. **ACL** (Access Control List) – Cisco, Juniper, Huawei и др.
   - Анализ на уровне L3–L4 (protocol, src/dst IP, src/dst port)
   - Небольшое количество дополнительных опций, простые сетевые объекты, наборы портов
   - **Линейный поиск** правил (first-match)
2. **iptables** – Linux-системы, MikroTik
   - Анализ на уровне L3–L4
   - Дополнительные опции и простые объекты
   - Линейный поиск, но с **механизмом цепочек** (chains)
3. **Политики безопасности NGFW** – Kaspersky, Positive Technologies, Fortinet и др.
   - Анализ на уровне L7 (приложения, сервисы, пользователи)
   - Богатый набор объектов: зоны, приложения и др.
   - Часто используется нелинейный поиск правил

Структура правил фильтрации

- Приоритет правила
- Действие - allow/deny/chain/return
- Условие совпадения:
  - Сетевые объекты (wildcard-маски, диапазоны IP, Geo-IP, FQDN)
  - Пользователи (группы, профили, идентификаторы)
  - Зоны безопасности и тип правила для работы с зонами
  - Сервисы (наборы портов и протоколов)
  - Приложения (прикладной протокол, сервис или группа приложений)
- Расписания
- Груповой профиль безопасности - объединяющий профиль движков безопасности (IDPS, AV, DNS Securiry)
- Дополнительные данные (число срабатываний, время последнего срабатывания, время первого срабатывания и тд)

Типы ошибок конфигурации правил и объектов

Правил:

- ! **Shadowing** — правило затенено, т.е. никогда не срабатывает
- ! **Redundancy** — избыточное правило
- ! **Generalization** — правило перекрывает более специфичное
- ! **Correlation** — частичное пересечение правил
- **Expired** — правило с истекшим сроком действия
- **Disabled** — правило отключено
- **Unused** — правило не используется

Объектов:

- **Unattached** — объект не привязан к правилу
- **Duplicate** — дублирующий объект
- **Unused within rule** — объект не используется с правилом

Сравнение методов анализа правил фильтрации

Критерий	**Семантический анализ**	**Тестирование на трафике**	**Формальная верификация**
Точность	Все типы ошибок	Не все логические ошибки	Все типы ошибок
Интерпретируемость	Легко	Может быть сложно	Легко
Требует реального трафика/исполнения	Нет	Да	Нет
Сложность	$O(n^2)$	Высокая (много тестов)	Обычно $O(n)$, в худшем случае $O(n^2)$
Проверка реального поведения	Нет	Да	Нет

Header Space Analysis - метод моделирования сети

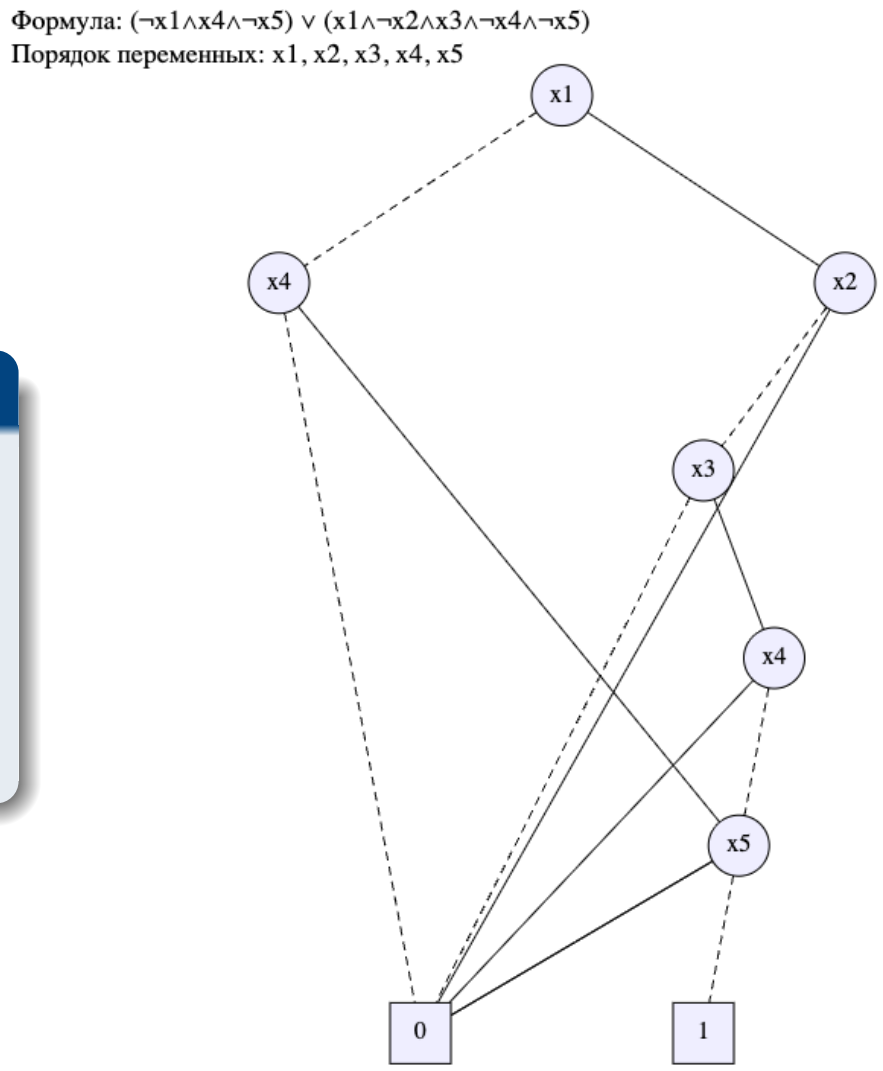
- Каждый пакет представлен как точка в многомерном пространстве заголовков сетевого пакета: $\{0,1\}^n$, где n - число битов в заголовке
- Для удобства вводят сцециальный символ wildcard x для обозначения любого бита
- На этом пространстве определены теоретико-множественные операции: пересечение, объединение, разность, дополнение и т.д.
- Правило фильтрации - это функция отображения в этом простанстве.

Множество пакетов P - это множество точек в пространстве заголовков, или объединение выражений с символами '0', '1' и 'x'. Это множество также можно задать с помощью булевой формулы.

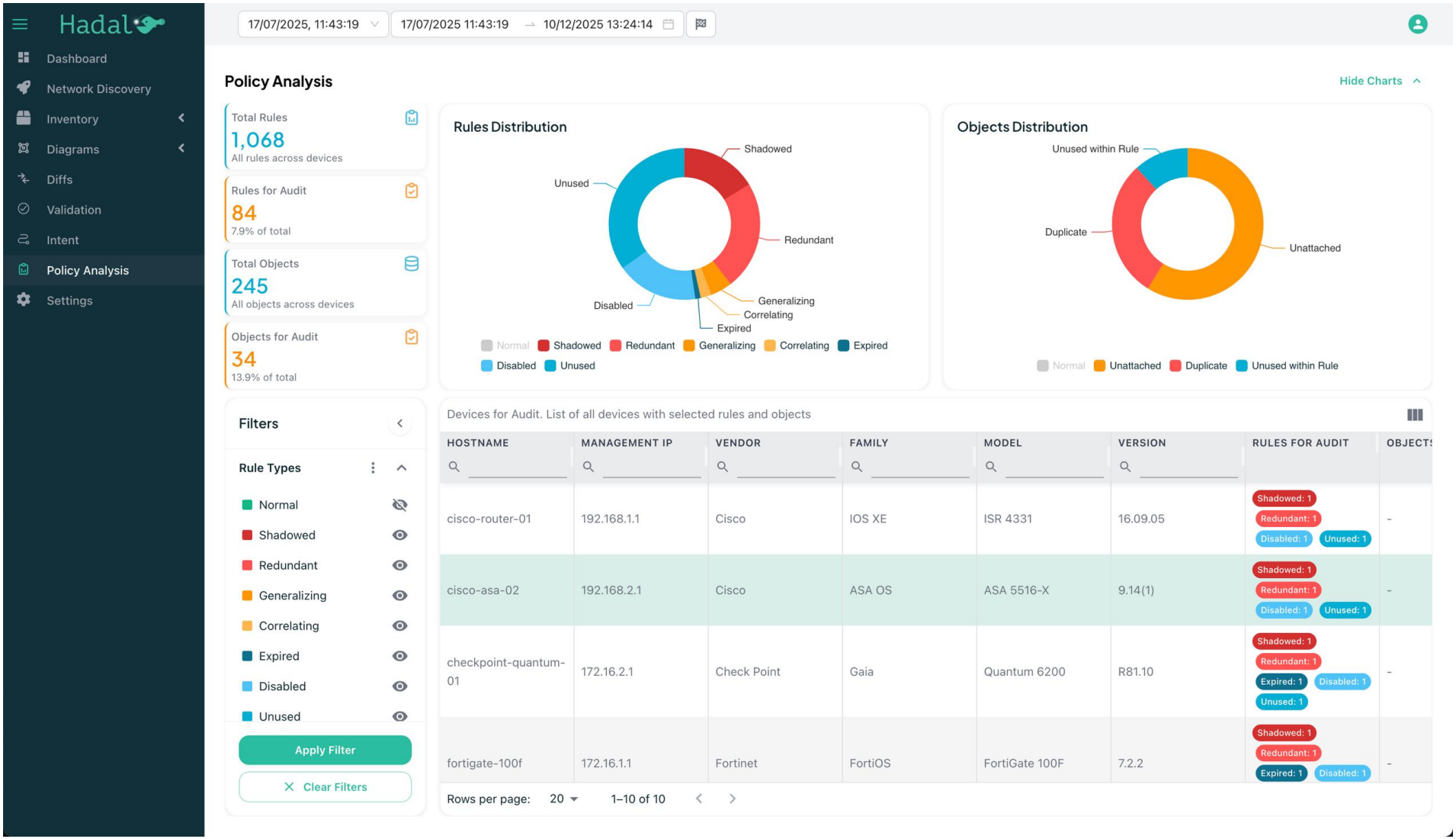
$$P = 0xx10 \cup 10100 \iff F(X) = (\neg x_1 \wedge x_4 \wedge \neg x_5) \vee (x_1 \wedge \neg x_2 \wedge x_3 \wedge \neg x_4 \wedge \neg x_5)$$

Binary Decision Diagrams (BDD)

- Компактное представление булевых функций
- Эффективные операции: пересечение, объединение, проверка эквивалентности



Система анализа правил фильтрации



Система анализа правил фильтрации

Hadal

17/07/2025, 11:43:19 | 17/07/2025 11:43:19 → 10/12/2025 13:24:14

- Dashboard
- Network Discovery
- Inventory
- Diagrams
- Diffs
- Validation
- Intent
- Policy Analysis
- Settings

Device Information

Hostname: cisco-router-01 **IP:** 192.168.1.1 **Vendor:** Cisco IOS XE **Model:** ISR 4331 **Version:** 16.09.05

Device Details

General
- General
- Configuration History
- Raw Outputs
- Policy Analysis

Tables
- Interfaces
- Managed IPv4 Addresses
- XDP Neighbors
- STP VLANs
- Switchport
- VLANs
- STP Virtual Ports
- MAC Table
- ARP Entries
- IPv4 Routing Table

Rules & Objects

Search...

- Objects
  - Network Objects (17)
  - Transport Ports Groups (5)
- ACL-CORP-1
  - INGRESS INTERFACES:
    - GigabitEthernet0/0
  - EGRESS INTERFACES:
    - GigabitEthernet0/1
- ACL-INSIDE-IN
- ACL-DMZ-IN
- ACL-OUTSIDE-IN
- ACL-EXTENDED-101
- ACL-STANDARD-10
- ACL-OUTBOUND-OUT

ACL-CORP-1 | ACL-INSIDE-IN

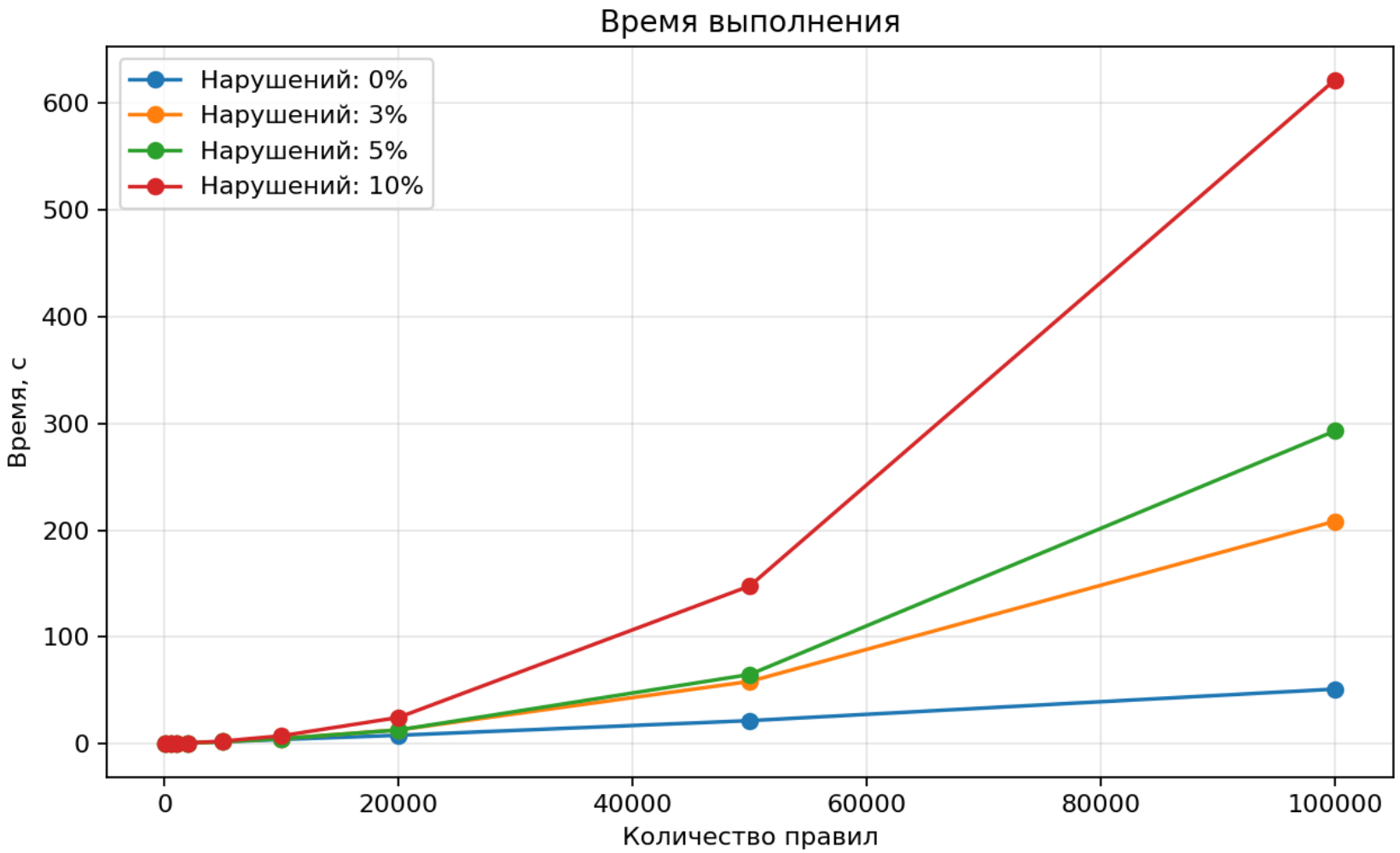
Only with recommendations

4 of 13

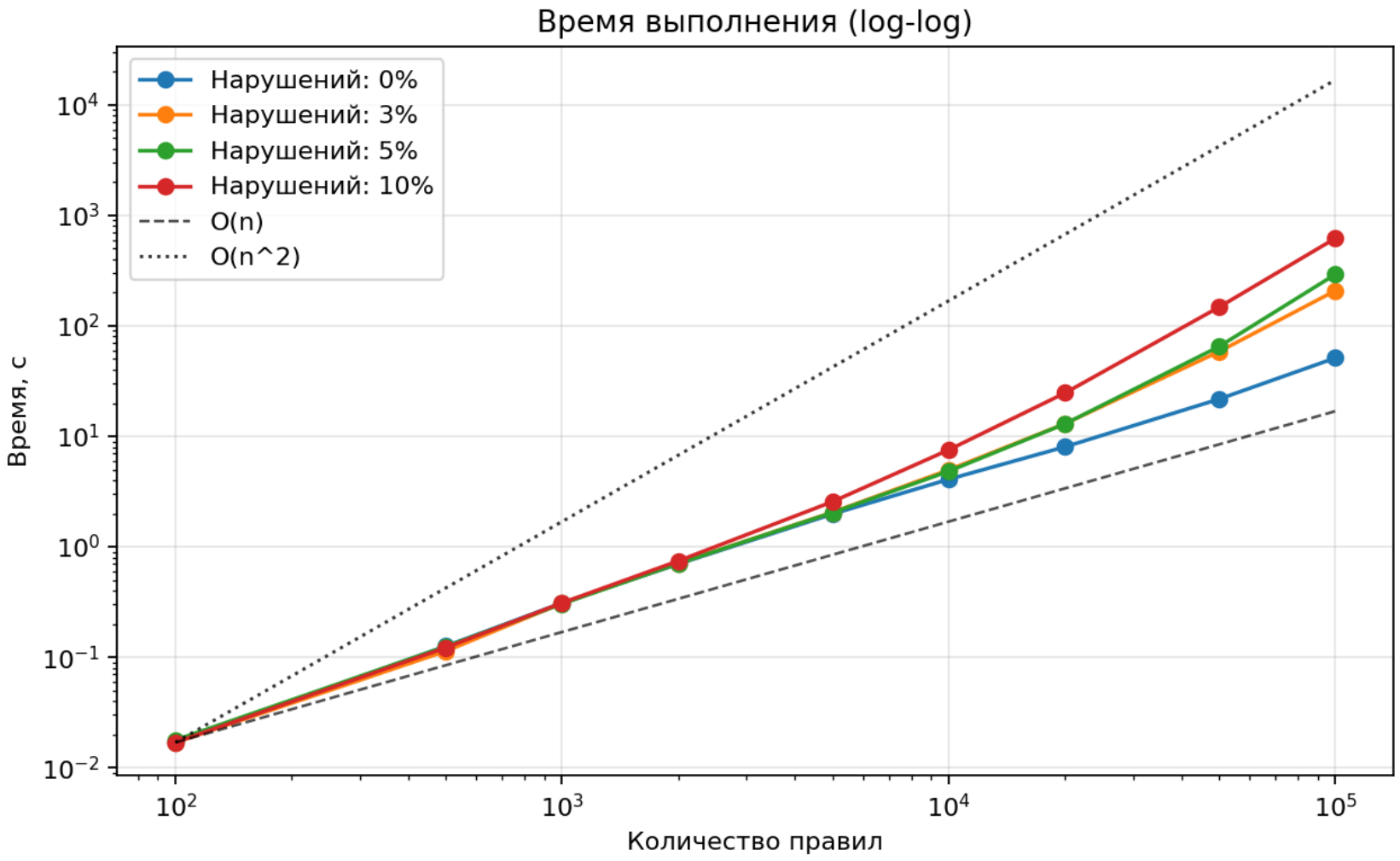
Custom

	BASIC				SOURCE		
	PRIORITY	ACTIVE	ACTION	RULE TYPE	SRC ENTRY	SRC NETWORKS	SRC USER
	10	✓	Deny	Universal	-	NET-10.1.1.0-25	-
	20	✓	Deny	Universal	-	NET-10.1.1.128-25	-
	30	✓	Deny	Universal	-	NET-10.1.1.0-26	-
	40	✓	Deny	Universal	-	NET-10.1.1.64-26	-
	50	✓	Deny	Universal	-	NET-10.1.1.128-26	-
warning redundant	60	✓	Deny	Universal	-	NET-10.1.1.192-26	-
	[illegible]	✓	Deny	Universal	-	-	-
	80	✓	Allow	Universal	-	NET-10.1.1.0-24	-
	90	✓	Allow	Universal	-	NET-192.168.99.0-24	-
	100	✓	Allow	Universal	-	HOST-192.168.99.56	-
	110	✓	Allow	Universal	-	HOST-192.168.99.57	-
	120	✓	Allow	Universal	-	NET-192.168.99.0-24	-
	130	✓	Deny	Universal	-	-	-

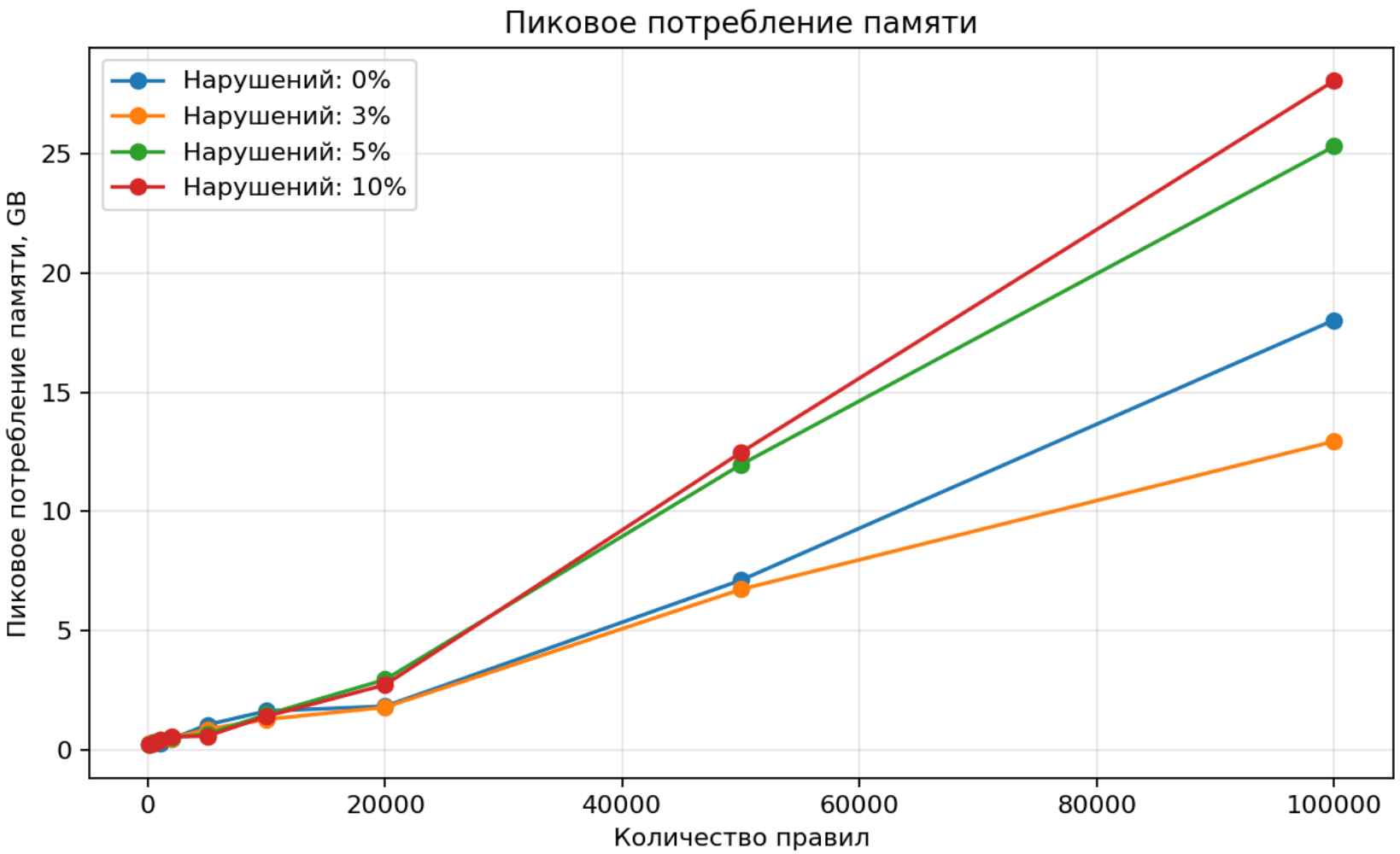
Время выполнения



Время выполнения (логарифмическая шкала)



Пиковое потребление памяти



Выполнено:

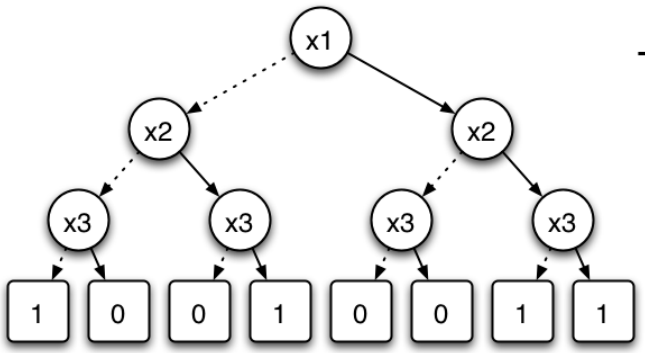
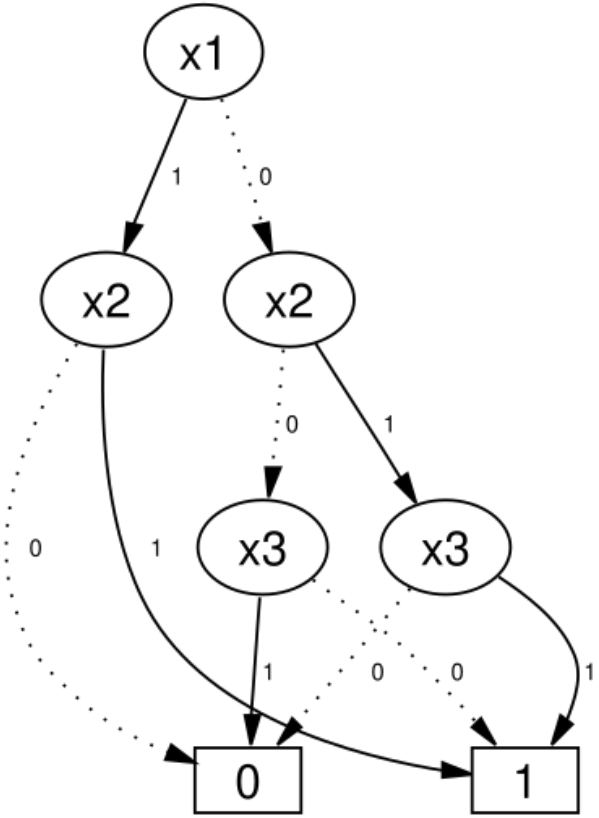
- Проведён анализ существующих методов верификации правил фильтрации
- Разработана унифицированная модель представления правил
- Выбран и адаптирован метод на основе BDD для анализа конфликтов
- Реализованы алгоритмы обнаружения основных типов аномалий
- Разработан прототип системы анализа

Практическая значимость:

- Снижение рисков мисконфигурации сетевых устройств
- Автоматизация аудита политик безопасности
- Поддержка мультивендорной инфраструктуры, в том числе и отечественных решений

Спасибо за внимание!

BDD



x1	x2	x3	*f*
0	0	0	1
0	0	1	0
0	1	0	0
0	1	1	1
1	0	0	0
1	0	1	0
1	1	0	1
1	1	1	1